

IT PROFESSIONAL PORTFOLIO

Cloud Engineering and Security Projects

PROJECT 43

Expose an S3 Bucket with ACLs for Public Access Testing

Amazon S3 | ACLs | Block Public Access | Object Ownership | Data Security

AUTHOR	Michael Salazar
ENVIRONMENT	Personal AWS Lab
VERSION	v1.0.0
RELEASE DATE	August 3, 2026
STATUS	Complete - Follow-Up Detection Pending

Executive Summary

Completed a controlled S3 exposure lab in **TestAccount1** to understand how legacy **Access Control Lists (ACLs)** can make an Amazon S3 bucket public. The lab intentionally disabled account-level and bucket-level **Block Public Access**, created a new S3 bucket with **ACLs enabled**, allowed public access, and edited the bucket ACL so the **Everyone** grantee had **List** and **Read** permissions. This deliberately unsafe configuration will be used in upcoming labs to test IAM Access Analyzer findings and Block Public Access remediation.

RISK NOTE

This is an intentionally unsafe lab state. The bucket should remain empty and should only be retained long enough to validate Access Analyzer and Block Public Access behavior in the next labs.

Business Problem

Amazon S3 is designed to store and serve objects over the Internet, which means bucket exposure is usually a configuration problem rather than a service compromise. Modern AWS defaults make accidental public access harder, but ACLs are a legacy access mechanism that still appears in real environments. Understanding the exact steps required to make an S3 bucket public helps explain how historical leaks occurred and why detection and preventive controls matter.

Objectives

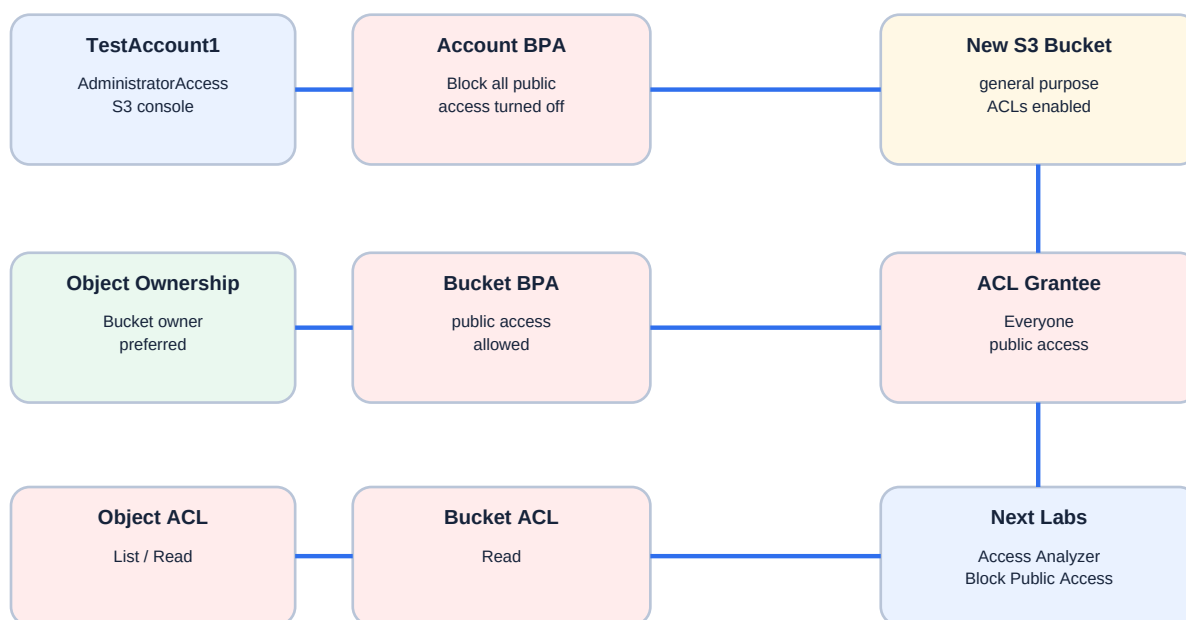
- * Sign into TestAccount1 with AdministratorAccess.
- * Open Amazon S3 and verify account-level Block Public Access settings.
- * Turn off account-level Block Public Access for the controlled lab.
- * Create a new S3 bucket for testing.
- * Enable ACLs through Object Ownership settings.
- * Allow public access at the bucket level by disabling bucket-level Block Public Access.
- * Edit the bucket Access Control List.
- * Grant the Everyone public-access grantee List and Read permissions.
- * Preserve the intentionally public configuration for upcoming Access Analyzer and Block Public Access labs.

Environment

Cloud Provider	Amazon Web Services (AWS)
Primary Services	Amazon S3, S3 Block Public Access, S3 Object Ownership, S3 Access Control Lists
Account Context	TestAccount1 / AdministratorAccess

Bucket Type	General purpose S3 bucket
Account Block Public Access	Off for controlled lab testing
Bucket Block Public Access	Disabled during bucket creation
Object Ownership	ACLs enabled with bucket owner preferred
ACL Grantee	Everyone / public access
Public Permissions	List and Read
Evidence	Block Public Access off and ACL public access configuration screenshots
Status	Intentionally public setup retained for next detection/prevention labs

Architecture



Public S3 ACL exposure requires disabling protective controls, enabling ACLs, then granting Everyone access.

Figure 1 - S3 ACL public exposure configuration path.

Implementation Summary

1. Signed into TestAccount1 with AdministratorAccess.
2. Opened Amazon S3 and navigated to account-level Block Public Access settings.

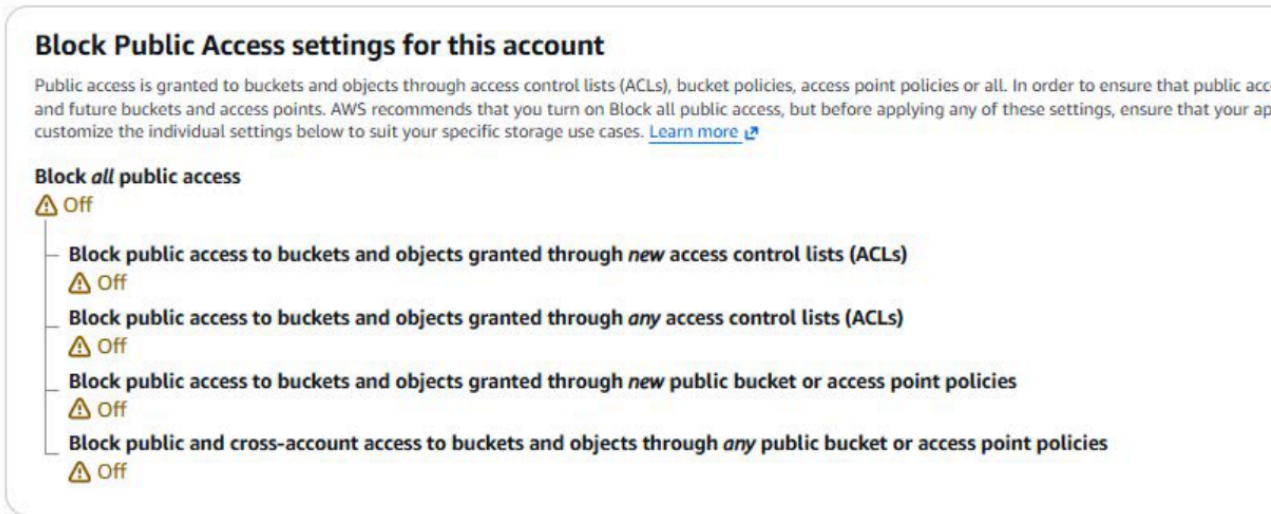
- 3. Verified Block Public Access was off for the lab path.
- 4. Created a new general purpose S3 bucket.
- 5. Enabled ACLs under Object Ownership settings.
- 6. Selected bucket owner preferred so the bucket owner remains the preferred owner of new objects.
- 7. Disabled bucket-level Block Public Access and acknowledged the AWS warnings.
- 8. Finished creating the bucket.
- 9. Opened the bucket Permissions tab and edited the Access Control List.
- 10. Granted the Everyone public-access grantee List and Read permissions.
- 11. Left the bucket configured for public access to support the next Access Analyzer and Block Public Access labs.

Control Map

Block Public Access	Account and bucket public-access blocks turned off	Protective guardrail was removed so ACL exposure could be tested.
Object Ownership	ACLs enabled, bucket owner preferred	ACL processing was re-enabled on a new bucket.
ACL Grantee	Everyone public access	Public Internet users became a valid access target.
Object permissions	List / Read	Public users can list bucket contents and read accessible objects.
Bucket ACL	Read	Bucket-level ACL read access is allowed for the public grantee.
Follow-up controls	Access Analyzer and Block Public Access next	The unsafe state supports detection and remediation validation.

Evidence

Figure 2 - Account-Level Block Public Access Turned Off



The S3 account-level Block Public Access evidence shows Block all public access set to Off. Each individual public-access block is also shown as Off, enabling the lab to proceed with public ACL testing.

Figure 3 - Bucket ACL Grants Everyone Public List and Read Access

Grantee	Objects	Bucket ACL
Bucket owner (your AWS account) Canonical ID: [redacted]	List, Write	Read, Write
Everyone (public access) Group: [redacted]	⚠ List	⚠ Read
Authenticated users group (anyone with an AWS account) Group: [redacted]	-	-
S3 log delivery group Group: [redacted]	-	-

The bucket ACL evidence shows the Everyone public-access grantee with List under Objects and Read under Bucket ACL. Account and group identifiers are redacted.

Security Analysis

S3 buckets are private by default, but S3 can intentionally serve objects over the Internet when configured to do so.

ACLs are a legacy access mechanism. They are disabled by default on new buckets unless Object Ownership is changed to enable them.

Granting Everyone permissions is the central risk. List allows public enumeration of bucket contents, and Read allows public retrieval of objects that ACLs make accessible.

Turning off Block Public Access removes a major guardrail that normally protects against accidental public exposure through ACLs, bucket policies, and access points.

The configuration is intentionally risky even if the bucket is empty. If sensitive data is uploaded later, exposure can occur immediately.

This lab should be followed by detection and remediation: IAM Access Analyzer should identify the public bucket, and Block Public Access should be re-enabled to prevent or override the exposure.

Lessons Learned

S3 has multiple access mechanisms: ACLs, bucket policies, and IAM policies.

ACLs are older, harder to reason about, and not recommended for most modern S3 access patterns.

S3 Object Ownership controls whether ACLs are processed on new buckets.

Public S3 exposure often requires multiple unsafe choices, but those choices can still happen in the console, CLI, API, or Infrastructure as Code.

Block Public Access is a critical protective layer and should normally remain enabled.

Public S3 exposure is easier to understand after seeing the full misconfiguration path end to end.

Production Improvements

- * Keep account-level and bucket-level Block Public Access enabled unless there is a documented exception.
- * Keep ACLs disabled by using Object Ownership set to bucket owner enforced.
- * Use bucket policies for deliberate public web-hosting use cases instead of ACLs.
- * Enable IAM Access Analyzer for S3 public and cross-account access findings.
- * Use AWS Config and Security Hub controls to detect public S3 buckets.
- * Apply Service Control Policies to prevent disabling Block Public Access in non-exception accounts.
- * Scan Infrastructure as Code for ACLs, public grantees, and public bucket policies before deployment.
- * Document and time-bound any public bucket exception with owner, purpose, data classification, and review date.

Skills Demonstrated

Block Public Access	Object Ownership	ACLs
Everyone grantee	Public List/Read	Bucket permissions
Misconfiguration analysis	Detection preparation	Remediation planning

Resume Bullet

RESUME

Built a controlled Amazon S3 public-exposure lab by disabling Block Public Access, enabling ACL processing, granting Everyone List and Read permissions, and documenting the resulting risk path for upcoming Access Analyzer and Block Public Access validation.

STAR Interview Story

Situation: The portfolio had covered compute, identity, logging, detection, and forensic workflows; the next data-security topic was public S3 exposure.

Task: Create a controlled public S3 bucket using ACLs so upcoming labs can validate Access Analyzer detection and Block Public Access prevention.

Action: I signed into TestAccount1, verified Block Public Access was off, created a new bucket, enabled ACLs with bucket owner preferred object ownership, allowed public access, edited the ACL, and granted the Everyone grantee List and Read permissions.

Result: The lab produced a deliberately public S3 configuration that demonstrates how ACL-based exposure happens and provides a target for the next detection and remediation labs.

Version History

v1.0.0	August 3, 2026	Initial documented implementation. Logged into TestAccount1, disabled Block Public Access for controlled testing, created S3 bucket, enabled ACLs, allowed public access, granted Everyone List and Read permissions, documented next-lab dependency for Access Analyzer and Block Public Access, and embedded provided evidence using portfolio documentation standard v1.0.1.

References

- * Cloud Security Lab a Week (S.L.A.W.) - Accidentally Expose All Your Stuff on S3 with ACLs.
- * User-provided Block Public Access off evidence screenshot.
- * User-provided public bucket ACL evidence screenshot.
- * Project 42 - Attach a Forensic Volume and Analyze Snapshot Evidence.